

Controls and compliance checklist

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☒	☐	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☒	☐	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☒	☐	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.

- ☒ ☐ Data integrity ensures the data is consistent, complete, accurate, and has been validated.
 - ☒ ☐ Data is available to individuals authorized to access it.
-

Recommendations:

Based on the audit findings, Botium Toys should prioritize implementing stronger access controls by enforcing the principles of least privilege and separation of duties to reduce unauthorized access to sensitive data. Customer payment information and personally identifiable information (PII/SPII) should be encrypted both in transit and at rest to ensure confidentiality and compliance with PCI DSS and GDPR requirements.

The organization should deploy an Intrusion Detection System (IDS) to improve threat detection capabilities and establish a centralized password management system with stronger password complexity requirements and Multi-Factor Authentication (MFA). Regular backups should be implemented and supported by a formal Disaster Recovery Plan (DRP) and Business Continuity Plan (BCP) to ensure business operations can recover from cyber incidents or system failures.

Additionally, Botium Toys should maintain a complete inventory of organizational assets, establish a scheduled maintenance process for legacy systems, and conduct regular cybersecurity awareness training for employees. These improvements will reduce organizational risk, strengthen regulatory compliance, and enhance the overall security posture of the company.